

Applied Cybersecurity Workshop

Secure Architecture & Incident Response

1. Company Snapshot

2–3 sentences summarizing the company and the challenge it's facing.

-The challenge facing Medlink Telehealth is it being a small company with a small IT team, and facing rapid growth in the next 6 months. They will have to scale rapidly with limited resources stemming from a small team, and small budget.

2. Architecture Decision

Model chosen (on-prem / cloud / hybrid / edge) and justification.

-A hybrid model seems to be the best option for this due to the company already having servers on premises, but needing to scale quickly, while also maintaining compliance with things like HIPPA, and other regulations. They need to stay in compliance, with flexibility to scale rapidly. Hybrid seems to fit this model the best, although a complete cloud may be feasible in the future.

3. Security Model Decision

Zero trust or perimeter-based, and justification.

-Zero trust seems to be the best option due to sensitivity of patient records, and information. It also limits lateral movement in case of infiltration. Implementing least privilege is ideal here.

4. Cloud Service Model & Shared Responsibility

If applicable — which model(s) chosen and the responsibility split.

-Hybrid was chosen with SaaS initially, but later needing PasS. SaaS initially due to limited resources, but as the company grows, the need to create apps, or content may present itself, and there would be a need for PasS. The company will need more help in the beginning, but after growth (hopefully growth of IT team) there may arise a need for more control of apps, and security measures.

5. Virtualization / Container Considerations

Isolation or image-security concerns identified, and how you'd address them.

-For the sake of security, and due to the sensitive nature of patient records, a VM model is preferred due to image-security concerns. It best protects patient information.

6. Trade-offs Identified

At least two, each with a concrete way you'll manage the risk.

-Using hybrid models the concern is complexity, and managing systems. Using VM's is slower than using container methods, and makes scaling slower. This is balancing security, with availability. To combat these issues the IT team should be grown to meet demands, and also be flexible to changing one of these, or both if situation changes, or calls for it.

7. Vulnerability Triage

How you prioritized the incident using CVSS, asset criticality, and exploitability together.

-This is a high priority, and needs immediate mitigation attention. It has a high CVSS score (> 7), and is already public. Restrict access. Monitor closely. Patch after change management when ready. This is a critical asset to this company, and if discovered by an attacker could cause serious data loss, financial loss, and public scrutiny.

8. Mitigation Plan

At least two immediate actions taken while a permanent fix is pending.

- Restrict access
- monitor closely
- close unused applications and ports

9. Vulnerability Lifecycle Walkthrough

One to two sentences per stage: Discovery, Triage, Response, Remediation, Recovery & Review.

- Discovery: Medlink's security monitoring flags and advisory.
- Triage: High priority— requires immediate action.
- Response: Restrict access, monitor closely, segment if possible. Close unnecessary ports.
- Remediation: Once the patch is ready - go through the change management process, and then apply.

-Recovery and Review: Talk about and review incidents, and discuss ways to mitigate this in the future. Review security policies, and ensure updates are happening with regularity.

10. Documentation & Escalation Plan

Who is notified, in what order, and why.

-Based on given information in the scenario, it does not sound like patient information was leaked out, but due to potential for it, the IT team, security, administration, and legal team should be notified in that order. Due to HIPPA regulations there might be regulations that were violated, or compliance(hence the admin and legal team) that needs to be met.

11. Lessons Learned (optional)

2–3 sentences reflecting on what your team would do differently.

-As a lesson learned, if Zero trust was not implemented, then employing that along with other security measures such as: SIEM, IDS, MFA, and other technical tools could help reduce risk of breach, and keep patient information more secure. Also implementing employee training on a regular basis, and having a culture of accountability. When dealing with patient information and records, you need the best security possible.